HỆ THỐNG QUẢN LÝ KHO

Đặc tả hệ thống cho kiểm thử tự động (QA / Automation Test Spec)

Môi trường: local (H2) và **online đã deploy** – Render (Docker, gói Free) + Aiven for MySQL (gói Free), theo DEPLOY.md bước 1–7.

Phiên bản mã nguồn: `qlkho-web` 1.0.0 (Spring Boot 3.3, Java 17). Tài liệu mô tả **hành vi thực tế của mã nguồn**, không phải hành vi mong muốn. Chỗ nào code có thể sai so với đặc tả nghiệp vụ được đánh dấu **RỦI RO** để ưu tiên viết test.

0. Hướng dẫn cho Claude Code

Mục tiêu: viết bộ test tự động để **tìm bug**, không chỉ để xác nhận chức năng chạy. Ưu tiên các ca biên, quyền truy cập và tương tác giữa các vai trò.

1. Đọc mục 1–3 để hiểu kiến trúc và cách chạy. Dùng mục 8 (dữ liệu mẫu) làm giá trị kỳ vọng ban đầu.
2. Viết **test API** trước (mục 6, 7): JUnit 5 + `@SpringBootTest` + `MockMvc`, CSDL H2 in-memory. Mỗi test class khởi tạo CSDL mới để dữ liệu mẫu được nạp lại.
3. Viết **test E2E** (mục 9, 10): Playwright (TypeScript). Địa chỉ lấy từ biến `BASE_URL`: mặc định `http://localhost:8080`, hoặc link Render khi chạy trên bản online (mục 2.5). Bộ đầy đủ cần CSDL sạch (mục 2.3).
4. Trên **bản online**, chỉ chạy bộ **smoke** không phá dữ liệu (mục 2.7). Các test đồng thời, xóa dữ liệu hoặc đổi trạng thái tài khoản/kho chỉ chạy trên local hoặc một CSDL riêng.
5. Khi một test thất bại do **hành vi của code** (không phải do test viết sai), ghi lại thành bug theo mẫu ở mục 12 và **không sửa test cho khớp với bug**.
6. Chạy các ca trong mục 11 (Rủi ro) như các test riêng, đặt tên có tiền tố `risk_`.

> Không chỉnh sửa mã nguồn ứng dụng khi viết test, trừ khi được yêu cầu. Nếu cần thêm cấu hình cho test (vd. `application-test.properties`), đặt trong `src/test/resources`.

1. Tổng quan kiến trúc

Tầng	Công nghệ	Vị trí trong mã nguồn
Giao diện (FE)	Một file HTML + JS thuần, render bằng chuỗi HTML, gọi REST bằng `fetch` (cookie phiên)	`src/main/resources/static/index.html`
REST API (BE)	Spring Boot 3.3, Spring Web, Jackson. Lỗi trả JSON `{"error": "..."}`	`com.qlkho.web.*Controller`, `Dto`
Nghiệp vụ	Service + `@Transactional`	`com.qlkho.service.*`
Truy cập dữ liệu	Spring Data JPA (Hibernate), không dùng quan hệ @ManyToOne – khóa ngoại là chuỗi id	`com.qlkho.repo.*`, `com.qlkho.model.*`
CSDL	Local: H2 file `./data/qlkho` (mặc định) hoặc MySQL (profile `mysql`). **Online: MySQL 8 trên Aiven** (profile `prod`, kết nối SSL)	`application.properties`, `application-mysql.properties`, `application-prod.properties`
Lưu file PDF	Trong CSDL: bảng `ho_so_noi_dung` (LONGBLOB). Không dùng ổ đĩa máy chủ	`CatalogService.store/readFile`
Triển khai	Docker 2 giai đoạn (Maven build → JRE 17). Render Free: 512 MB RAM, tự deploy khi `git push` lên nhánh `main`	`Dockerfile`, `render.yaml`
Xác thực	HttpSession **lưu trong bộ nhớ** (cookie `JSESSIONID`), thuộc tính `uid`. Mật khẩu BCrypt. **Không có CSRF**, không có Spring Security. Profile `prod`: cookie `Secure`, `HttpOnly`, `SameSite=Lax`	`AuthService`

Luồng dữ liệu giao diện: sau mỗi thao tác ghi, FE gọi lại `GET /api/state` để tải toàn bộ dữ liệu (hàm `sync()`), rồi vẽ lại màn hình. Trạng thái giao diện tạm thời (bộ lọc, form nháp, phiên kiểm kê đang mở) chỉ nằm trong bộ nhớ trình duyệt và mất khi tải lại trang.

2. Chạy ứng dụng và môi trường test

2.1 Chạy local

```
cd qlkho-web
mvn spring-boot:run            # http://localhost:8080
# hoặc: mvn clean package && java -jar target/qlkho-web-1.0.0.jar
```

2.2 Cấu hình đề xuất cho test API

```
# src/test/resources/application-test.properties
spring.datasource.url=jdbc:h2:mem:qlkho-${random.uuid};DB_CLOSE_DELAY=-1
spring.jpa.hibernate.ddl-auto=create-drop
spring.h2.console.enabled=false

# Trong test class:
@SpringBootTest @AutoConfigureMockMvc @ActiveProfiles("test")
@DirtiesContext(classMode = DirtiesContext.ClassMode.AFTER_CLASS)
```

`DataSeeder` (CommandLineRunner) tự nạp dữ liệu mẫu khi bảng `nguoi_dung` trống, nên mỗi context mới đều có dữ liệu như mục 8.

2.3 Đưa dữ liệu về ban đầu cho E2E

- H2 local: dừng ứng dụng, xóa thư mục `data/`, chạy lại.
- MySQL: `DROP TABLE` 11 bảng (danh sách ở mục 5) rồi khởi động lại.
- Không có API reset. Nếu cần chạy E2E song song, mỗi worker phải có CSDL riêng.

2.4 Đăng nhập trong test API

```
MockHttpSession s = new MockHttpSession();
mvc.perform(post("/api/auth/login").session(s).contentType(APPLICATION_JSON)
    .content("{\"phone\":\"0902222222\",\"password\":\"123456\"}"))
   .andExpect(status().isOk());
// dùng lại session s cho các request tiếp theo
```

2.5 Môi trường online (đã deploy)

Hạng mục	Giá trị / hành vi
Địa chỉ	`https://<tên-service>.onrender.com` – thay bằng link thật của nhóm, truyền vào test qua biến `BASE_URL`. **Luôn dùng https** (cookie Secure không gửi qua http)
Profile, CSDL	`SPRING_PROFILES_ACTIVE=prod`; MySQL Aiven qua `DB_URL` (`jdbc:mysql://…?sslMode=REQUIRED…`), `DB_USER`, `DB_PASSWORD`. Bảng do Hibernate tự tạo (`ddl-auto=update`). Pool kết nối tối đa **4**
Kiểm tra sống	`GET /api/public/summary` (cũng là Health Check Path của Render) – trả 200 + JSON
Ngủ / thức dậy	Ngủ sau 15 phút không có truy cập. Request đầu tiên có thể mất **30–60 giây** hoặc trả 502 tạm thời
Phiên đăng nhập	Lưu trong bộ nhớ máy chủ ⇒ **mất khi máy chủ ngủ, khởi động lại hoặc deploy lại**. Người dùng phải đăng nhập lại (hành vi đúng: giao diện về trang đăng nhập, không lỗi)
Dữ liệu	**Dùng chung** cho mọi người dùng thử. Có thể đã khác dữ liệu mẫu ở mục 8. Mật khẩu Admin có thể đã được đổi (DEPLOY.md bước 5)
Cập nhật code	`git push` ⇒ Render tự build và deploy lại (3–6 phút). Dữ liệu MySQL giữ nguyên
Đưa dữ liệu về ban đầu	DEPLOY.md bước 8: `DROP TABLE` 11 bảng trên Aiven rồi **Restart service** trên Render ⇒ dữ liệu mẫu được nạp lại

2.6 Cấu hình Playwright cho cả local và online

```
// playwright.config.ts
export default defineConfig({
  use: { baseURL: process.env.BASE_URL ?? 'http://localhost:8080' },
  timeout: 90_000,                    // chừa thời gian cho Render thức dậy
  expect: { timeout: 10_000 },
  retries: process.env.BASE_URL?.includes('onrender.com') ? 1 : 0,
```

```
  workers: process.env.BASE_URL?.includes('onrender.com') ? 1 : undefined,  // dữ
liệu dùng chung
});

// global-setup.ts: đánh thức máy chủ trước khi chạy
for (let i = 0; i < 12; i++) {
  const r = await fetch(baseURL + '/api/public/summary').catch(() => null);
  if (r?.ok) break; await new Promise(f => setTimeout(f, 10_000));
}

// Tài khoản lấy từ biến môi trường (mặc định = dữ liệu mẫu)
ADMIN_PHONE=0901111111  ADMIN_PASS=123456
MANAGER_PHONE=0902222222 MANAGER_PASS=123456
STAFF_PHONE=0903333333   STAFF_PASS=123456
```

2.7 Phân loại test theo môi trường

Nhóm test	Local (H2 / MySQL riêng)	Online (Render + Aiven)
Smoke: health, đăng nhập 3 vai trò, `/api/state` theo bảng 4.2, quyền xem file PDF (403/200), mở từng màn hình	✓	✓ (**chỉ đọc**)
Luồng F1–F10 đầy đủ, giá trị kỳ vọng theo mục 8	✓	Chỉ sau khi đưa dữ liệu về ban đầu (bước 8), chạy 1 worker
Kiểm tra quy tắc BR (ca lỗi 400)	✓	✓ – các ca bị từ chối không ghi dữ liệu
Đồng thời, tải (RISK-01/02/03, RISK-19, RISK-20)	✓	× – làm hỏng dữ liệu dùng chung và vượt pool 4 kết nối
Khóa / xóa tài khoản, tạm ngưng / xóa kho	✓	× – có thể khóa nhóm khỏi bản demo
Khác biệt H2 ↔ MySQL (RISK-16)	MySQL qua Testcontainers	✓ – smoke trên bản online chính là MySQL thật

> Mọi dữ liệu do test tạo trên bản online nên có tiền tố dễ nhận biết, vd. tên “[TEST] …” hoặc ghi chú phiếu “auto-test”, để nhóm dọn dẹp sau.

3. Vai trò và tài khoản mẫu

Mã	Họ tên	SĐT đăng nhập	Mật khẩu	Vai trò (role)	Trạng thái
U1	Nguyễn Văn An	0901111111	123456	admin – Quản trị viên	active
U2	Trần Thị Bình	0902222222	123456	manager – Quản lý kho	active
U3	Lê Minh Cường	0903333333	123456	staff – Nhân viên kho	active
U4	Phạm Thu Dung	0904444444	123456	staff	locked
U5	Hoàng Gia Huy	0905555555	123456	staff	draft

> Trên bản online, mật khẩu Admin có thể đã bị đổi theo DEPLOY.md bước 5 ⇒ test không được gán cứng, phải đọc từ biến môi trường (mục 2.6). Thẻ “Tài khoản demo” trên trang đăng nhập luôn điền mật khẩu `123456`.

Quan hệ giữa vai trò (thực tế trong code): không có kế thừa quyền tự động. Mỗi endpoint liệt kê rõ vai trò được phép (`auth.require(session, "admin", "manager")`). Về nghiệp vụ: Nhân viên kho lập chứng từ → Quản lý kho duyệt/xác nhận → Quản trị viên quản lý tài khoản và kho. Quản trị viên có mọi quyền của Quản lý kho, **trừ** việc xem liên hệ/hồ sơ bị ẩn theo bảng 4.2 (Admin không bị ẩn gì).

4. Ma trận phân quyền

4.1 Chức năng

Ký hiệu: ✓ được phép, × bị chặn. Cột "Chặn ở đâu" cho biết test nào cần viết: **API** = máy chủ trả 403; **UI** = chỉ ẩn nút/menu.

Chức năng	Admin	Manager	Staff	Chặn ở đâu / ghi chú
Đăng nhập (SĐT + mật khẩu)	✓	✓	✓	Tài khoản draft/locked bị từ chối
Xem Tổng quan, Tồn kho, Thẻ kho, Cảnh báo, Báo cáo	✓	✓	✓	Không giới hạn
Lập phiếu nhập / xuất	✓	✓	✓	API: mọi người đã đăng nhập
Duyệt / từ chối phiếu	✓	✓	×	API 403 với staff. Thêm: **không duyệt được phiếu do chính mình lập** (400)
Mở phiên kiểm kê, nhập số thực tế	✓	✓	✓	Chỉ ở trình duyệt, không gọi API
Xác nhận kiểm kê (điều chỉnh tồn)	✓	✓	×	API 403; UI hiện thông báo thay cho nút
Thêm hàng hóa	✓	✓	×	API 403 + UI ẩn nút
Xem danh sách NCC / khách hàng	✓	✓	✓	—
Thêm / sửa NCC, khách hàng; lưu ghi chú	✓	✓	×	API 403; UI ẩn nút
Xem / tải PDF của **NCC**	✓	×	×	API 403 (bị ẩn theo 4.2)
Tải lên / xóa PDF của **NCC**	✓	×	×	Cần role admin|manager **và** không bị ẩn ⇒ chỉ admin
Xem / tải PDF của **khách hàng**	✓	✓	×	API 403 với staff
Tải lên / xóa PDF của **khách hàng**	✓	✓	×	API 403 với staff
Xem danh sách kho	✓	✓	✓	—
Thêm / sửa / tạm ngưng / xóa kho	✓	×	×	API 403; UI ẩn nút
Quản lý người dùng	✓	×	×	API 403; menu "Người dùng" chỉ hiện với admin

4.2 Ẩn thông tin liên hệ và hồ sơ (Rules.HIDE_CONTACT)

Áp dụng **tại máy chủ** trong `GET /api/state`: trường bị ẩn trả về chuỗi rỗng `""` (đối tác) hoặc `null` (kho, người dùng).

Dữ liệu	Admin	Manager	Staff	Trường bị lược
Nhà cung cấp (`sup`): SĐT, email, PDF	Thấy	Ẩn	Ẩn	`suppliers[].phone`, `.email` = ""; `files` không chứa file của NCC
Khách hàng (`cus`): SĐT, email, PDF	Thấy	Thấy	Ẩn	`customers[].phone`, `.email` = ""; `files` không chứa file của KH
Kho (`wh`): SĐT kho	Thấy	Thấy	Ẩn	`warehouses[].phone` = null
SĐT người dùng (danh sách `users`)	Thấy	Thấy	Ẩn	`users[].phone` = null (staff)

> **Địa chỉ** và **ghi chú** đối tác KHÔNG bị ẩn với vai trò nào. Khi manager sửa NCC, máy chủ bỏ qua `phone`/`email` gửi lên và giữ giá trị cũ.

5. Mô hình dữ liệu và quan hệ

Bảng (Entity)	Khóa chính	Trường chính	Liên kết (khóa ngoại logic)
nguoi_dung (UserAccount)	id: U1, U2…	name, phone (unique), passwordHash, role, opened yyyy-MM-dd, status	—
kho (Warehouse)	id: HN, HCM, DN…	code KHO-XX (unique), name, address, phone, capacity (0 = không giới hạn),	keeperId → nguoi_dung.id (có thể

Bảng (Entity)	Khóa chính	Trường chính	Liên kết (khóa ngoại logic)
		opened, status active|paused	null)
hang_hoa (Product)	id: P01…	sku (unique), name, category, unit, minStock, price	—
ton_kho (Stock)	id = "P01|HN"	qty ≥ 0	productId → hang_hoa, warehouseId → kho
doi_tac (Partner)	id: NCC-01, KH-01	partnerType sup|cus, name, phone, email, address, note, noteAt, noteBy	—
phieu (Receipt)	id = mã phiếu PN-0001 / PX-0001	receiptType in|out, createdAt, status pending|approved|cancelled, creatorId, creatorName, approverName, note, sortKey	partnerId → doi_tac, warehouseId → kho
chi_tiet_phieu (ReceiptLine)	id tự tăng	qty > 0	receiptId → phieu, productId → hang_hoa
the_kho (StockHistory)	id tự tăng	happenedAt, kind Nhập|Xuất|Kiểm kê, delta, qtyAfter, ref (mã chứng từ)	productId, warehouseId
phieu_kiem_ke (Stocktake)	id = KK-0001	createdAt, checkedCount, diffCount, confirmedBy	warehouseId
ho_so_doi_tac (PartnerFile)	id = UUID	fileName, fileSize, uploadedAt, uploadedBy, storedPath ("db" hoặc đường dẫn cũ)	partnerId → doi_tac
ho_so_noi_dung (PartnerFileContent)	id = id hồ sơ	data (LONGBLOB)	1–1 với ho_so_doi_tac

> JPA **không tạo ràng buộc khóa ngoại** (không dùng @ManyToOne). Toàn vẹn tham chiếu chỉ do code đảm bảo – đây là nguồn bug tiềm năng (mục 11).

5.1 Vòng đời trạng thái

Đối tượng	Chuyển trạng thái hợp lệ	Ghi chú
Phiếu	pending → approved | cancelled	Không có chuyển nào khác. Phiếu đã xử lý không sửa/xóa được (không có API).
Tài khoản	draft ↔ active ↔ locked (admin đặt bất kỳ giá trị nào qua API status)	Chỉ xóa khi locked. Không tự đổi trạng thái/xóa chính mình.
Kho	active ↔ paused	Tạm ngưng khi không còn phiếu chờ và còn ≥ 1 kho active khác. Xóa khi paused + tồn 0 + không có phiếu chờ.

5.2 Sinh mã

- Phiếu: `PN-` / `PX-` + (số lớn nhất hiện có + 1), 4 chữ số. Kiểm kê: `KK-xxxx`. Hàng hóa: `P` + 2 chữ số. Đối tác: `NCC-xx`, `KH-xx`. Người dùng: `U` + số. Kho: phần sau `KHO-` của mã kho.
- Cách sinh “max + 1” đọc toàn bộ bảng rồi tính, **không có khóa** – xem RISK-02.

6. Quy tắc nghiệp vụ (kèm thông báo lỗi chính xác)

Tất cả lỗi nghiệp vụ trả **HTTP 400** với `{"error": "<thông báo>"}` (404 khi không tìm thấy, 401 chưa đăng nhập, 403 không đủ quyền). Có thể assert trực tiếp chuỗi thông báo.

Mã	Phạm vi	Quy tắc	Thông báo lỗi (chuỗi chính xác)
BR-01	Đăng nhập	SĐT chuẩn hóa (bỏ khoảng trắng, dấu chấm, gạch). Hợp lệ: `^0[35789]\d{8}$`	Số điện thoại không hợp lệ (10 số, bắt đầu bằng 03, 05, 07, 08 hoặc 09).
BR-02	Đăng nhập	Sai SĐT hoặc mật khẩu dùng chung 1 thông báo	Sai số điện thoại hoặc mật khẩu.
BR-03	Đăng nhập	Tài khoản locked / draft bị từ chối	Tài khoản đã bị khóa. Vui lòng liên hệ Quản trị viên. / Tài khoản chưa được kích hoạt. Vui lòng liên hệ Quản trị viên.

Mã	Phạm vi	Quy tắc	Thông báo lỗi (chuỗi chính xác)
BR-04	Phiên	Mỗi request kiểm tra lại người dùng; nếu đã bị khóa/xóa → hủy phiên, 401	Phiên đăng nhập không còn hiệu lực. Vui lòng đăng nhập lại.
BR-05	Lập phiếu	Phải có ≥ 1 dòng; qty nguyên > 0; không trùng mặt hàng	Phiếu chưa có mặt hàng nào… / Số lượng của “X” phải là số nguyên lớn hơn 0. / Mặt hàng “X” bị trùng trong phiếu.
BR-06	Lập phiếu	Đối tác đúng loại (in→sup, out→cus); kho phải active	Đối tác không phù hợp với loại phiếu. / <Tên kho> đang tạm ngưng, không thể lập phiếu.
BR-07	Lập phiếu xuất	qty ≤ tồn hiện tại của kho xuất	Không đủ tồn: “X” chỉ còn N <ĐVT> tại <Kho>.
BR-08	Lập phiếu	Tạo phiếu **không** thay đổi tồn kho	—
BR-09	Duyệt	Chỉ phiếu pending; người duyệt ≠ người lập	Phiếu X đã được xử lý trước đó. / Bạn không thể tự duyệt phiếu do chính mình lập.
BR-10	Duyệt xuất	Kiểm tra tồn lần 2 khi duyệt	Không thể duyệt X: “Y” chỉ còn N <ĐVT> tại <Kho>.
BR-11	Duyệt	Cộng/trừ tồn từng dòng, ghi 1 dòng the_kho/dòng (ref = mã phiếu); trả về `low` = tên mặt hàng có tồn sau xuất ≤ minStock	—
BR-12	Từ chối	pending → cancelled, ghi approverName; tồn không đổi	—
BR-13	Kiểm kê	actual nguyên ≥ 0; kho active. Chỉ dòng có actual ≠ tồn hiện tại mới ghi the_kho (kind “Kiểm kê”). Luôn tạo KK-xxxx kể cả khi không lệch	Số thực tế của “X” phải là số nguyên ≥ 0.
BR-14	Hàng hóa	SKU, tên, ĐVT bắt buộc; SKU không trùng (không phân biệt hoa thường); minStock ≥ 0; price ≥ 0; category trống → “Khác”	Vui lòng nhập Mã SKU, Tên hàng hóa và Đơn vị tính. / Mã SKU “X” đã tồn tại.
BR-15	Đối tác	Tên bắt buộc; cần SĐT hoặc email; SĐT `^0\d{9,10}$`; email hợp lệ	Cần ít nhất một thông tin liên hệ: số điện thoại hoặc email.
BR-16	Hồ sơ PDF	Đuôi .pdf, ≤ 10 MB, 4 byte đầu là `%PDF`	<tên> không phải file PDF. / không phải file PDF hợp lệ. / File vượt quá 10 MB.
BR-17	Người dùng	SĐT hợp lệ + không trùng; mật khẩu ≥ 6 ký tự, không khoảng trắng; role ∈ {admin, manager, staff}; opened yyyy-MM-dd; status sai → mặc định draft	Số điện thoại X đã được dùng cho tài khoản khác. / Mật khẩu phải có ít nhất 6 ký tự.
BR-18	Sửa người dùng	Chỉ sửa SĐT và mật khẩu (trống = giữ nguyên)	Chưa có thay đổi nào để lưu.
BR-19	Xóa người dùng	Chỉ khi locked; không xóa chính mình. Chứng từ cũ giữ creatorName/approverName	Hãy khóa tài khoản X trước, sau đó mới có thể xóa.
BR-20	Kho	Mã `^KHO-[A-Z0-9]{2,10}$` (tự in hoa) không trùng; tên không trùng (không phân biệt hoa thường); địa chỉ bắt buộc; capacity ≥ 0 và ≥ tồn hiện tại khi sửa	Mã kho phải có dạng KHO-XXX… / Sức chứa (A) không được nhỏ hơn số lượng đang tồn (B).
BR-21	Thủ kho	keeperId phải là manager/staff; phải active (trừ khi giữ nguyên người cũ)	Thủ kho phải là Quản lý kho hoặc Nhân viên kho. / Chỉ chọn được tài khoản đang hoạt động làm thủ kho.
BR-22	Tạm ngưng kho	Không còn phiếu pending; còn ≥ 1 kho active khác	Không thể tạm ngưng X: còn N phiếu chờ duyệt… / Phải có ít nhất một kho đang hoạt động.
BR-23	Xóa kho	paused + tổng tồn 0 + không pending; xóa các dòng ton_kho của kho; giữ phiếu/thẻ kho cũ	Hãy tạm ngưng X trước… / Không thể xóa X: kho còn N đơn vị hàng…
BR-24	Cảnh báo tồn thấp	(mặt hàng, kho active) có tồn ≤ minStock. Kho paused không tính. Đề xuất nhập (FE) = max(2×min − tồn, 1)	—

7. REST API

Tiền tố `/api`. Request/response JSON (UTF-8). Phiên qua cookie. Thứ tự trong cột “Quyền” là vai trò được phép; mọi endpoint khác `/auth/*` và `/public/*` đều yêu cầu đăng nhập (401 nếu chưa).

Phương thức + đường dẫn	Quyền	Body gửi lên	Trả về khi thành công
POST /auth/login	Công khai	{phone, password}	{id, name, role, roleLabel}; đặt phiên
POST /auth/logout	Công khai	—	{ok:true}; hủy phiên
GET /auth/me	Công khai	—	{user: {...} | null}
GET /public/summary	Công khai	—	{low, pending, total, warehouses}
GET /state	Đăng nhập	—	Toàn bộ dữ liệu (mục 7.1)
POST /receipts	Đăng nhập	{type:"in"|"out", partnerId, warehouseId, note, lines:[{productId, qty}]}	{code}
POST /receipts/{id}/approve	admin, manager	—	{code, type, low:[tên mặt hàng]}
POST /receipts/{id}/reject	admin, manager	—	{code}
POST /stocktakes	admin, manager	{warehouseId, rows:[{productId, actual}]}	{code, diff, warehouse}
POST /products	admin, manager	{sku, name, category, unit, minStock, price}	{id, name}
POST /partners	admin, manager	{type:"sup"|"cus", name, phone, email, address, note}	{id}
PUT /partners/{id}	admin, manager	{name, phone, email, address}	{id}
PUT /partners/{id}/note	admin, manager	{note}	{id}
POST /partners/{id}/files	admin, manager + không bị ẩn	multipart, field `file`	{id}
GET /files/{id}[?download=1]	Đăng nhập + không bị ẩn	—	application/pdf, Content-Disposition inline/attachment
DELETE /files/{id}	admin, manager + không bị ẩn	—	{ok:true}
POST /users	admin	{name, phone, password, role, opened, status}	{id, name}
PUT /users/{id}	admin	{phone, password}	{id, name}
PUT /users/{id}/status	admin	{status}	{id, name, before, status}
DELETE /users/{id}	admin	—	{name}
POST /warehouses	admin	{code, name, address, keeperId, phone, capacity, opened, status}	{id, name}
PUT /warehouses/{id}	admin	như trên (code, opened bị bỏ qua)	{id, name}
PUT /warehouses/{id}/status	admin	{status:"active"|"paused"}	{id, name, status}
DELETE /warehouses/{id}	admin	—	{name}

7.1 Cấu trúc GET /api/state

```
{
  "me": {"id","name","role","roleLabel"},
  "users": [{"id","name","phone|null","role","opened","status"}],
  "warehouses": [{"id","code","name","address","keeperId","phone|
null","capacity","opened","status"}],
  "products": [{"id","sku","name","cat","unit","min","price"}],
  "stock": {"P01|HN": 120, ...},
```

```
  "suppliers" | "customers":
[{"id","name","phone","email","address","note","noteAt","noteBy"}],
  "receipts":
[{"id","code","type","partner","wh","date","status","creator","creatorId","approver",
"note","lines":[{"pid","qty"}]}],  // mới nhất trước
  "history": [{"t","pid","wh","kind","delta","after","ref"}],
// id giảm dần
  "kkList": [{"code","date","wh","checked","diff","by"}],
  "files": [{"id","partnerId","name","size","date","by"}],    // đã lọc theo quyền
  "seq": {"in", "out", "kk"},                                  // số kế tiếp (mã dự
kiến)
  "hideContact": {"sup":[...], "cus":[...], "wh":[...]}
}
```

8. Dữ liệu mẫu và giá trị kỳ vọng ban đầu

> Các giá trị dưới đây **chỉ đúng ngay sau khi CSDL vừa được tạo** (local mới, hoặc bản online sau DEPLOY.md bước 8). Trên bản online đang dùng chung, test smoke không được so sánh số tuyệt đối – chỉ kiểm tra cấu trúc và quan hệ (vd. tồn sau duyệt = tồn trước ± số lượng).

Mã	SKU	Tên	ĐVT	Min	Giá vốn	Tồn HN	Tồn HCM
P01	SP-0001	Giấy in A4 70gsm	Ram	50	65.000	120	35 ⚠️
P02	SP-0002	Bút bi xanh (hộp 20)	Hộp	30	48.000	80	60
P03	SP-0003	Bìa hồ sơ nhựa	Cái	100	6.000	90 ⚠️	150
P04	SP-0004	Mực in laser đen	Hộp	10	420.000	6 ⚠️	14
P05	SP-0005	Chuột không dây	Cái	15	180.000	22	18
P06	SP-0006	Bàn phím có dây	Cái	10	250.000	12	4 ⚠️
P07	SP-0007	Cáp USB-C 1m	Sợi	40	55.000	55	70
P08	SP-0008	Nước rửa tay 500ml	Chai	24	42.000	30	26

Chỉ số	Giá trị kỳ vọng
Cảnh báo tồn thấp (`/public/summary.low`)	**4** (đánh dấu ⚠️ ở bảng trên)
Phiếu chờ duyệt	**2**: PN-0002 (NCC-02 → HCM: P05×20, P06×15), PX-0002 (KH-02, HCM: P02×20). Cả hai do **U3** lập
Phiếu đã duyệt	PN-0001 (NCC-01 → HN: P01×100, P02×50), PX-0001 (KH-01, HN: P01×30, P03×40); người duyệt Trần Thị Bình
Tổng tồn	**792** (HN 415, HCM 377); giá trị tồn 47.062.000 đ
Thẻ kho	4 dòng (từ PN-0001, PX-0001)
Kiểm kê	KK-0001 (HN, 8 mặt hàng, lệch 0)
Kho	HN (KHO-HN, thủ kho U2, sức chứa 2000), HCM (KHO-HCM, thủ kho U3, sức chứa 1500); đều active
Đối tác	NCC-01..03, KH-01..03. Hồ sơ PDF: NCC-01 (2 file), NCC-02 (1), KH-01 (1)
Mã kế tiếp	PN-0003, PX-0003, KK-0002, P09, NCC-04, KH-04, U6

9. Luồng tương tác giữa các vai trò (kịch bản E2E)

Luồng	Vai trò	Bước và kỳ vọng
F1 – Xuất kho → duyệt → cảnh báo	staff → manager	Staff lập PX từ Kho Hà Nội: P02 × 60 (tồn 80). Kỳ vọng: phiếu PX-0003 pending, tồn vẫn 80. Manager duyệt → tồn P02|HN = 20, thẻ kho có dòng "Xuất −60, sau 20, PX-0003", response `low` chứa "Bút bi xanh (hộp 20)", cảnh báo tồn thấp tăng 4 → 5.
F2 – Không tự duyệt	manager →	Manager lập PN. Manager gọi approve → 400 "Bạn không thể tự

Luồng	Vai trò	Bước và kỳ vọng
	admin	duyệt…"; UI không hiện nút Duyệt cho phiếu đó. Admin duyệt → thành công.
F3 – Kiểm tra tồn lần 2	staff ×2 → manager	Staff lập 2 phiếu xuất P06 tại HCM, mỗi phiếu qty 4 (tồn 4) – cả hai được tạo (phiếu pending không giữ chỗ). Manager duyệt phiếu 1 → tồn 0. Duyệt phiếu 2 → 400 "Không thể duyệt …: "Bàn phím có dây" chỉ còn 0 Cái tại Kho TP.HCM.", phiếu 2 vẫn pending.
F4 – Kiểm kê bàn giao	staff → manager (cùng trình duyệt)	Staff mở kiểm kê HN, sửa P01 = 119. UI không có nút xác nhận; gọi POST /stocktakes bằng phiên staff → 403. Đăng xuất, manager đăng nhập trong **cùng tab** → phiên kiểm kê vẫn còn (lưu trong bộ nhớ trang) → xác nhận → KK-0002, tồn P01|HN = 119, thẻ kho "Kiểm kê −1".
F5 – Vòng đời tài khoản	admin → user mới	Admin tạo U6 (draft) → đăng nhập U6 bị từ chối "chưa được kích hoạt". Admin kích hoạt → U6 đăng nhập được. Admin khóa U6 khi U6 đang đăng nhập ở trình duyệt khác → request tiếp theo của U6 trả 401 và giao diện về trang đăng nhập. Xóa U6 khi chưa khóa → 400; sau khi khóa → xóa được; phiếu U6 đã lập vẫn hiện tên U6.
F6 – Kho mới	admin → staff	Admin tạo KHO-DN (thủ kho U3). Staff thấy "Kho Đà Nẵng" khi lập phiếu; cảnh báo tồn thấp tăng 8 (mọi mặt hàng tồn 0 ≤ min). Admin tạm ngưng DN → biến mất khỏi form lập phiếu/kiểm kê, cảnh báo giảm 8. Xóa DN → thành công (tồn 0).
F7 – Bảo mật liên hệ	cả 3	So sánh `/api/state` theo bảng 4.2. Staff gọi GET /files/{id} của NCC-01 hoặc KH-01 → 403. Manager GET file NCC-01 → 403, file KH-01 → 200.
F8 – Hồ sơ PDF	admin, manager	Admin tải PDF lên NCC-03 → manager không thấy trong `files`. Manager tải PDF lên KH-02 → staff không thấy. Tải file .txt đổi tên .pdf → 400 "không phải file PDF hợp lệ".
F9 – Cảnh báo → nhập bổ sung	staff → manager	Từ màn Cảnh báo, "Tạo phiếu nhập" cho P04|HN → form điền sẵn qty = 2×10 − 6 = 14. Lập phiếu, manager duyệt → P04|HN = 20, cảnh báo giảm 1.
F10 – Thủ kho bị khóa	admin	Khóa U3 (thủ kho HCM) → danh sách kho hiện cảnh báo "Tài khoản đã khóa"; sửa kho HCM mà giữ nguyên keeper U3 → được phép; đổi keeper sang U4 (locked) → 400.

10. Giao diện – cấu trúc và selector cho Playwright

10.1 Điều hướng

- Trang chủ `#home` hiện đầu tiên (khi chưa đăng nhập). Vào trang đăng nhập: bấm vào `#home`, nhấn phím `ArrowUp`/`Enter`, cuộn chuột hoặc kéo lên.
- Menu trái: các nút `button.nav` có chữ: Tổng quan, Nhập kho, Xuất kho, Kiểm kê, Tồn kho, Cảnh báo tồn thấp, Báo cáo, Hàng hóa, Nhà cung cấp, Khách hàng, Kho, Người dùng (chỉ admin). Ví dụ: `page.click("aside >> text=Xuất kho")`. Lưu ý chữ "Kho" trùng với "Nhập kho"… → dùng `aside button.nav:has-text("Kho") >> nth=-1`.
- Tiêu đề màn hình: `main h1`. Thông báo nổi: `.toast` (tự ẩn sau ~4,2 giây). Lỗi trong form: `.alert-err`.

10.2 Ô nhập (thuộc tính `data-fid`)

Màn hình	data-fid
Đăng nhập	`login-user` (SĐT), `login-pass`; thẻ tài khoản demo `.rolecard` (nth 0 = admin, 1 = manager, 2 = staff); nút `.auth-card button.btn-primary`
Nhập / xuất kho	`rc-search-in|out`, `rc-qty-{in|out}-{i}` (dòng thứ i), `rc-note-in|out`. Chọn hàng: `.pick` (bấm để thêm). Nút "Lưu phiếu và gửi duyệt". Danh sách: `#rc-list .trow`
Kiểm kê	Nút "Bắt đầu kiểm kê", ô `kk-{i}`, nút "Xác nhận và điều chỉnh tồn"
Tồn kho	`inv-q`; checkbox "Chỉ hiện tồn thấp"; nút "Thẻ kho"
Hàng hóa	`pr-q`, `pf-sku`, `pf-name`, `pf-cat`, `pf-unit`, `pf-min`, `pf-price`
NCC / Khách hàng	`pq`, `pf2-name`, `pf2-phone`, `pf2-email`, `pf2-address`, `pf2-note`, `p-note`; tên đối tác `[data-hp="NCC-01"]` (rê chuột → popup `#hpop`); chi tiết `#p-detail`; danh sách `#p-list`; upload

Màn hình	data-fid
	`input[data-file="NCC-01"]`
Kho	`wq`, `wf-code`, `wf-name`, `wf-address`, `wf-phone`, `wf-cap`, `wf-opened`; chọn thủ kho: `.keeperbox` → popup có `kp-q`, dòng `.kpick-row`; xác nhận xóa: `wdel-ack`
Người dùng	`uq`, `uf-name`, `uf-phone`, `uf-pass`, `uf-opened`; bảng `#user-table`; xác nhận xóa: `del-ack`, nút hủy `del-cancel`

10.3 Thành phần dùng chung

- Thẻ số liệu bấm để lọc: `.statbtn` (đang lọc có class `on` và nhãn "Đang lọc"). Nút lọc dạng viên: `.pill`, đang chọn `.pill.on`.
- Bảng: dòng `.trow`, dòng được tô `.trow.hl`. Popup xác nhận: `.overlay > .dialog`; đóng bằng Esc hoặc bấm nền.
- Mọi nút đều có `data-c` (chỉ số handler nội bộ, **không ổn định** giữa các lần vẽ) – không dùng làm selector; dùng chữ trên nút hoặc `data-fid`.
- Giao diện vẽ lại toàn bộ sau mỗi thao tác: phần tử cũ bị thay. Luôn truy vấn lại locator sau khi thao tác, không giữ ElementHandle.

11. Rủi ro / nghi vấn bug cần ưu tiên kiểm thử

Danh sách dưới đây là những điểm **đọc code thấy có khả năng sai**. Mỗi mục nên có ít nhất một test mang tiền tố `risk_`.

Mã	Mô tả nghi vấn	Cách kiểm thử gợi ý	Kỳ vọng đúng
RISK-01	Duyệt cùng một phiếu đồng thời: `approve` kiểm tra status rồi mới cập nhật, không khóa dòng / không optimistic lock ⇒ có thể **trừ tồn 2 lần**	Bắn 2–5 request approve song song (2 phiên admin + manager) cho cùng phiếu xuất	Chỉ 1 request thành công; tồn chỉ thay đổi 1 lần; thẻ kho 1 bộ dòng
RISK-02	Sinh mã "max+1" không khóa ⇒ 2 phiếu tạo cùng lúc có thể trùng mã → lỗi 500 hoặc ghi đè	Tạo 10 phiếu song song	Tất cả thành công, mã khác nhau, không có 500
RISK-03	Hai phiếu xuất cùng lúc có thể làm tồn âm? `setQty` ném lỗi khi âm nhưng việc kiểm tra và ghi không nguyên tử	Duyệt song song 2 phiếu xuất cùng mặt hàng, tổng > tồn	Một phiếu bị từ chối; tồn ≥ 0
RISK-04	Kiểm kê so với **tồn lúc xác nhận**, không phải tồn lúc bắt đầu phiên. Nếu có phiếu được duyệt giữa chừng, số đếm ghi đè biến động đó	Bắt đầu kiểm kê HN; duyệt 1 phiếu nhập vào HN; xác nhận kiểm kê	Cần quyết định nghiệp vụ; hiện tại biến động bị "nuốt" → ghi nhận là bug thiết kế
RISK-05	Không có khóa ngoại thật: xóa tài khoản đang là thủ kho → `keeperId` trỏ tới id không tồn tại	Khóa + xóa U3 rồi GET /state	UI hiện "Tài khoản đã xóa"; không lỗi 500
RISK-06	Manager nhận được **SĐT của mọi người dùng** (kể cả admin) trong `/api/state.users` – có thể là rò rỉ thông tin	Đăng nhập manager, đọc `users[].phone`	Theo đặc tả quyền riêng tư, chỉ admin nên thấy
RISK-07	Đặc tả UC01 yêu cầu khóa tạm sau 5 lần sai mật khẩu – **chưa được cài đặt**	Đăng nhập sai 6 lần	Lần 6 phải bị khóa tạm (hiện tại: không)
RISK-08	Mật khẩu chỉ kiểm tra độ dài tối thiểu. BCrypt chỉ dùng 72 byte đầu (hoặc ném lỗi với một số phiên bản Spring Security) ⇒ mật khẩu rất dài hoặc nhiều ký tự Unicode có thể gây 500 hoặc trùng khớp ngoài ý muốn	Tạo user với mật khẩu 100 ký tự; đăng nhập bằng 72 ký tự đầu + chuỗi khác	400 với thông báo rõ ràng, hoặc chỉ khớp đúng mật khẩu
RISK-09	XSS: tên đối tác/hàng hóa/ghi chú có `<script>` hoặc `"><img onerror>`	Tạo dữ liệu chứa HTML rồi mở các màn hình, popup `#hpop`	Hiển thị dạng chữ, không thực thi
RISK-10	Không có CSRF token; cookie phiên SameSite=Lax chỉ ở profile prod	POST từ origin khác (form tự gửi)	Ghi nhận mức độ rủi ro

Mã	Mô tả nghi vấn	Cách kiểm thử gợi ý	Kỳ vọng đúng
RISK-11	Báo cáo: nhãn kỳ cố định "Tháng 11/2026"; tồn đầu kỳ tính từ **toàn bộ** thẻ kho, không lọc theo tháng. Xuất Excel/PDF chỉ là thông báo mô phỏng	Tạo biến động có ngày khác; mở Báo cáo	Ghi nhận là hạn chế đã biết
RISK-12	Phiên kiểm kê chỉ lưu trong bộ nhớ trang: tải lại trang là mất số đã đếm	Mở kiểm kê, sửa số, F5	Ghi nhận hạn chế
RISK-13	Sửa kho sang paused qua `PUT /warehouses/{id}` có kiểm tra như API status; nhưng **sửa kho đang paused** với capacity < tồn vẫn bị chặn – kiểm tra các tổ hợp	Bảng tổ hợp status × capacity	Thông báo nhất quán
RISK-14	Giá trị biên: qty rất lớn (> 2^31), số thập phân, chuỗi; JSON sai kiểu	Gửi `qty: 2147483648`, `1.5`, `"abc"`	400 với thông báo rõ ràng, không 500
RISK-15	Upload: chỉ kiểm tra đuôi + magic bytes; tên file chứa ký tự đặc biệt / rất dài (> 255)	Upload tên dài 300 ký tự, tên có `../`	Từ chối hoặc lưu an toàn, không 500
RISK-16	H2 và MySQL khác nhau (LONGBLOB, so sánh chuỗi không phân biệt hoa thường)	Chạy lại bộ test API với profile MySQL (Testcontainers); smoke trên bản online	Kết quả như H2
RISK-17	Phiên lưu trong bộ nhớ: Render ngủ / restart / deploy ⇒ mọi người bị đăng xuất. Giao diện phải tự về trang đăng nhập khi API trả 401, không treo hoặc hiện lỗi khó hiểu	Đăng nhập, Restart service trên Render (hoặc khởi động lại app local), thao tác tiếp	Thông báo "Phiên đăng nhập…", về trang đăng nhập; đăng nhập lại dùng bình thường
RISK-18	Cookie `Secure` ở profile prod: truy cập qua `http://` thì đăng nhập thành công nhưng các request sau báo chưa đăng nhập	Mở bản online bằng http (nếu Render không tự chuyển hướng); chạy local với `prod` + `COOKIE_SECURE` mặc định	Có chuyển hướng sang https, hoặc thông báo rõ ràng
RISK-19	Pool tối đa 4 kết nối + gói free: nhiều người dùng cùng lúc ⇒ chờ kết nối (timeout 20 giây) rồi lỗi 500	Local với cấu hình prod + MySQL: 20 request `/api/state` song song	Chậm nhưng không 500; nếu 500 ⇒ bug cấu hình
RISK-20	`/api/state` trả **toàn bộ** dữ liệu mỗi lần thao tác ⇒ chậm dần khi dữ liệu tăng (thẻ kho, phiếu)	Local: tạo 2.000 phiếu + duyệt, đo thời gian `/api/state` và thời gian vẽ màn hình	Ghi nhận ngưỡng; > 2 giây là vấn đề hiệu năng
RISK-21	Upload PDF 8–10 MB vào MySQL qua kết nối free (giới hạn gói tin, bộ nhớ 512 MB khi đọc cả file vào RAM)	Local MySQL + bản online (1 lần): upload file 9,9 MB rồi xem	Thành công hoặc báo lỗi rõ ràng; máy chủ không bị khởi động lại (exit 137)

12. Mẫu báo cáo bug

```
ID: BUG-xxx            Mức độ: Critical | Major | Minor
Liên quan: BR-xx / RISK-xx / Fx
Môi trường: local-H2 | local-MySQL | online-Render (link, giờ chạy)
Vai trò: admin | manager | staff
Bước tái hiện:
  1. ...
Kết quả thực tế: ... (kèm response JSON / ảnh chụp)
Kết quả mong đợi: ...
Test phát hiện: <tên file>::<tên test>
```

Checklist độ phủ tối thiểu

- Mỗi endpoint: 1 ca thành công + ca 401 (chưa đăng nhập) + ca 403 cho từng vai trò bị chặn + các ca 400 theo BR.
- Mỗi luồng F1–F10: 1 test E2E đầy đủ, kiểm tra cả dữ liệu (qua API) lẫn giao diện.
- Mỗi dòng trong bảng 4.2: kiểm tra ở cả `/api/state` và trên giao diện (danh sách, chi tiết, popup, màn lập phiếu).
- Mỗi RISK: 1 test `risk_` – được phép thất bại, nhưng phải có báo cáo bug đi kèm.

- Bản online: bộ smoke (mục 2.7) chạy được bằng `BASE_URL=https://<link> npx playwright test --grep @smoke` và **không để lại thay đổi** ngoài các bản ghi có tiền tố [TEST].
- Báo cáo bug ghi rõ môi trường: `local-H2`, `local-MySQL` hoặc `online-Render`.